INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY

GRC103 – RISK ASSESSMENT AND MANAGEMENT TECHNIQUES

Module 2: Risk Analysis And Evaluation

Role:Lead GRC Analyst

Lab 3: Advanced Cybersecurity Risk Quantification Report

Student Name	Olubunmi Adesanmi
Registration number	C11/26/CGRCE 17550
Course	Grc 103-Risk Assessment and management techniques
Module	Risk Identification Techniques
Link to workbook	https://docs.google.com/spreadsheets/d/1dCu9Bug49fMa7zUJZJGHlCyH_sgZbSq5LG6EB2u9cTg/edit?usp=sharing
Role	Lead Risk Analyst
Submission Date	Nov 1

Document Title	Quantitative Cybersecurity Risk Assessment Report
System Under Assessment	SecureMobile Banking Platform
Organization	SecureBank Financial

Prepared by	Lead GRC Analyst
Prepared for	Chief Information Security Officer (CISO) and Chief Financial Officer (CFO)
Assessment Purpose	Quantify financial risk, evaluate proposed controls and recommend risk treatments
Evaluation Period	Three years
Version	1.0
Classification	Internal— Academic Case Study

TABLE OF CONTENTS

1. Executive Summary
2. Introduction
3. Assessment Objectives and Scope
4. System Context and Assessment Data
5. Methodology and Modelling Assumptions
6. Phase 1: Risk Exposure Calculation
    - 6.1 Single Loss Expectancy (SLE)
    - 6.2 Annual Rate of Occurrence (ARO)
    - 6.3 Annualised Loss Expectancy (ALE)
        i. 6.4 Risk Prioritisation Matrix
        ii. 6.5 Risk Distribution and Visualisation
    - Phase 2: Security Control Evaluation
        i. 7.1 Proposed Security Controls
        ii. 7.2 Risk Reduction and Residual Risk
        iii. 7.3 Control Cost-Benefit Analysis
        iv. 7.4 Return on Investment (ROI)
        v. 7.5 Payback Period
        vi. 7.6 Control Selection and Limitations
    - Phase 3: Executive Dashboard and Reporting
    - Risk Treatment Plan and Implementation Timeline
    - Monitoring, Measurement and Assurance
    - Limitations and Key Assumptions
    - Conclusion and Management Recommendations

- References

1. EXECUTIVE SUMMARY

1.1 Overview

SecureBank Financial conducted a quantitative cybersecurity risk assessment of its SecureMobile banking platform following a penetration test and vulnerability assessment that identified three critical security weaknesses: API authentication bypass, database injection and session hijacking. These vulnerabilities present potential threats to the confidentiality, integrity and availability of banking services, customer information and financial transactions.

SecureMobile supports 500,000 active customers and processes approximately 50,000 transactions daily, with an average transaction value of $2,500. This represents an indicative transaction throughput of $125,000,000 per day. This figure represents transaction value processed by the platform and must not be interpreted as the amount that would necessarily be lost in a security incident.

The purpose of this assessment is to quantify the potential financial exposure associated with the identified vulnerabilities, prioritise the risks, evaluate the proposed security controls and recommend cost-effective risk treatments. The analysis uses the quantitative risk formulas provided in the study guide, including Single Loss Expectancy (SLE), Annual Rate of Occurrence (ARO), Annualised Loss Expectancy (ALE), residual risk, risk reduction, return on investment (ROI) and payback period.

1.2 Key Risk Assessment Findings

The assessment estimates combined annual loss exposure of **$35,000,000** across the three risk scenarios under the assumptions stated in this report.

Database injection represents the largest modelled financial exposure. The estimated single-event loss is $125,000,000, based on 500,000 customer records at an assumed cost of $250 per record. Applying the supplied 25% probability as an annual occurrence-rate proxy produces a modelled ALE of $31,250,000.

Session hijacking has the highest supplied exploit probability, at 40%, and a modelled ALE of $3,000,000. API authentication bypass has a supplied probability of 15% and a modelled ALE of $750,000. Although the API scenario has the lowest modelled ALE, unauthorised fund transfers could still cause material financial and operational harm.

Summary of Quantified Cybersecurity Risks

No.	Vulnerability	Single Loss Expectancy (SLE)	Assumed Annual Probability	Modelled ALE	Priority
1	API authentication bypass	$5,000,000	15%	$750,000	High
2	Database injection	$125,000,000	25%	$31,250,000	Critical
3	Session hijacking	$7,500,000	40%	$3,000,000	High
	Total	—	—	**$35,000,000**	—

The supplied probabilities do not specify a time period. For the purposes of this laboratory exercise, they are treated as assumed annual probability proxies and used as ARO values in a simplified model. This is an explicit modelling assumption, not a verified incident frequency or a guarantee of future loss.

1.3 Proposed Security Investment

Three controls have been evaluated: an Advanced API Security Gateway, a Web Application Firewall (WAF) and Multi-Factor Authentication (MFA) enhancement. For modelling purposes, each control is assigned to one primary risk scenario to prevent double-counting of its expected financial benefit.

Security Control Evaluation

Proposed Control	Initial Investment	Annual Maintenance	Modelled Annual Risk Reduction	Residual ALE
Advanced API Security Gateway	$350,000	$50,000	$675,000	$75,000
Web Application Firewall (WAF)	$150,000	$25,000	$23,437,500	$7,812,500
MFA enhancement	$200,000	$30,000	$2,850,000	$150,000
Total	**$700,000**	**$105,000/year**	**$26,962,500/year**	**$8,037,500**

If all three controls achieve their stated effectiveness against their assigned risk scenarios, the model estimates that annual loss exposure could reduce from $35,000,000 to $8,037,500. This represents a modelled annual reduction of approximately 77.0%.

1.4 Financial Justification

A three-year evaluation period is used to compare control benefits against implementation and maintenance costs. The combined initial investment is $700,000, with annual maintenance of $105,000. Total three-year lifecycle cost is therefore $1,015,000.

The model estimates gross expected loss avoided over three years at $80,887,500, producing a portfolio ROI of approximately 7,869.2% under the stated assumptions.

These results are modelled financial estimates, not guaranteed cash savings. The very high WAF ROI depends heavily on the assumed $125 million database-injection loss and the application of the WAF's stated effectiveness to this scenario. Both assumptions must be validated before the result is used to approve a real security budget.

1.5 Executive Recommendation

SecureBank Financial should prioritise remediation of database injection, supported by WAF deployment, while addressing the API authentication and session-management weaknesses through the other proposed controls.

The recommended programme should begin with immediate technical remediation, followed by staged deployment and effectiveness testing of the three controls. Approval should be subject to validation of the financial assumptions, confirmation that each control addresses the intended attack path, documented control ownership and ongoing residual-risk monitoring.

2. INTRODUCTION

Cybersecurity vulnerabilities can result in financial losses, regulatory exposure, operational disruption and damage to customer trust. For a banking platform, authentication, authorisation, database security and session management are essential safeguards because the application processes financial transactions and sensitive customer information.

Qualitative ratings such as High, Medium and Low help management understand relative severity. Quantitative risk analysis adds a financial perspective by estimating the potential loss from a single event and applying an assumed occurrence rate to estimate annualised loss exposure.

NIST Special Publication 800-30 provides guidance for conducting information security risk assessments and supporting management decisions about risk treatment (National Institute

of Standards and Technology [NIST], 2012). This report applies a simplified quantitative method appropriate to the data supplied in the SecureBank laboratory scenario.

The report also evaluates proposed security controls using the financial formulas in the supplied *Study Guide: Quantitative Risk Calculations for GRC Professionals*. The purpose is to demonstrate how a GRC analyst can translate technical findings into financial estimates, treatment priorities and management decisions.

2.1 Background

The penetration test and vulnerability assessment identified three security weaknesses:

1. API authentication bypass, which could enable unauthorised fund transfers.
2. Database injection, which could expose or alter customer and financial information.
3. Session hijacking, which could enable account takeover and unauthorised transactions.

The assessment assumes that SecureBank must decide how to allocate security investment across these risks while balancing financial exposure, operational practicality and the effectiveness of the proposed controls.

2.2 Purpose of the Report

The purpose of this report is to:

- Calculate SLE and ALE for each vulnerability.
- Prioritise risks according to likelihood and financial impact.
- Evaluate the proposed controls, including initial cost and annual maintenance.
- Calculate modelled risk reduction and residual risk.
- Calculate three-year ROI and estimated payback periods.
- Present data suitable for executive dashboards and risk visualisations.
- Recommend a phased risk treatment plan with accountability and measurable outcomes.

3. ASSESSMENT OBJECTIVES AND SCOPE

3.1 Objectives

The assessment seeks to determine the estimated financial consequences of the identified vulnerabilities, evaluate proposed security investments and provide a defensible basis for prioritising treatment.

The main objectives are:

1. Quantify the potential loss from one successful incident for each vulnerability.

2. Estimate annualised loss exposure using the supplied probability values as explicitly stated modelling proxies.
3. Rank vulnerabilities according to expected financial exposure and business consequences.
4. Assess how the proposed controls could reduce their assigned risk scenarios.
5. Compare control benefits against lifecycle costs over a three-year period.
6. Identify the residual risks that remain after the modelled controls are applied.
7. Recommend immediate, short-term and long-term risk treatment actions.

3.2 Scope

The assessment covers the following SecureMobile components and security concerns:

Area	Assessment Coverage
API security	Authentication bypass and unauthorised transaction processing
Database security	Injection, potential data exposure and customer-record impact
Session security	Session hijacking and account takeover
Financial exposure	Single-event loss, annualised loss exposure and expected risk reduction
Security controls	API Security Gateway, WAF and MFA enhancement
Investment analysis	Initial implementation, maintenance, ROI and payback
Executive reporting	Risk prioritisation, residual risk and treatment timeline

4. SYSTEM CONTEXT AND ASSESSMENT DATA

4.1 System Context

The SecureMobile banking platform has the following characteristics.

System Context

Attribute	Supplied Value

Active customers	500,000
Average transaction value	$2,500
Daily transactions	50,000
Indicative daily transaction throughput	$125,000,000
Currency	USD

Calculation of indicative daily transaction
50,000 x $2,500 = $125,000,000
This figure indicates the approximate value of transactions processed during a day. It does not represent expected fraud losses or the amount that would necessarily be affected by a vulnerability.

4.2 Vulnerability Assessment Data

Supplied Vulnerability Data

Vulnerability	Exploit Probability	Potential Impact	Financial Input
API authentication bypass	15%	Unauthorised fund transfers	Maximum single incident loss: $5,000,000
Database injection	25%	Exposure of personal and financial information	500,000 records at $250 per record
Session hijacking	40%	Account takeover	5,000 accounts or sessions at $1,500 average loss per account

The API authentication bypass scenario has a stated maximum single incident loss of $5,000,000. The database injection scenario derives its single-event loss from the number of records assumed affected and the stated cost per record. The session hijacking scenario derives its single-event loss from the number of accounts at risk and the average stated loss per account.

4.3 Proposed Security Controls

Table 5: Supplied Control Data

Control	Initial Cost	Effectiveness	Annual Maintenance
Advanced API Security Gateway	$350,000	90% reduction in API vulnerabilities	$50,000
Web Application Firewall (WAF)	$150,000	75% reduction in web vulnerabilities	$25,000
MFA enhancement	$200,000	95% reduction in account takeover	$30,000

The stated effectiveness figures are taken from the laboratory brief. They are treated as model inputs, not independently verified performance measurements.

5. METHODOLOGY AND MODELLING ASSUMPTIONS

5.1 Quantitative Risk Method

The assessment uses the following concepts:

Single Loss Expectancy (SLE): The estimated financial loss arising from one successful incident.

Annual Rate of Occurrence (ARO): The expected number of incidents per year.

Annualised Loss Expectancy (ALE): The estimated loss exposure per year calculated by multiplying SLE by ARO.

Residual Risk: The modelled risk remaining after a security control is applied.

Risk Reduction: The difference between the current modelled ALE and the residual ALE.

Return on Investment (ROI): The percentage return calculated by comparing the modelled benefit with the total relevant cost.

Payback Period: The estimated time required for modelled annual net benefit to recover the initial investment.

5.2 Important Assumption: Annual Probability Versus ARO

The laboratory brief provides exploit probabilities of 15%, 25% and 40% but does not specify whether these values refer to a month, year, test period or lifetime.

For this exercise, the values are interpreted as assumed annual probabilities of at least one event and are used as ARO proxies:

- API authentication bypass: 0.15
- Database injection: 0.25
- Session hijacking: 0.40

This approach supports completion of the exercise using the supplied ALE formula. However, it is an approximation. A probability of at least one event in a year is not automatically the same as an expected annual incident frequency, particularly where multiple events may occur.

5.3 Control Mapping Assumptions

For the base-case model, each control is assigned to one primary scenario:

Control	Primary Risk Assigned	Effectiveness Applied
Advanced API Security Gateway	API authentication bypass	90%
Web Application Firewall (WAF)	Database injection	75%
MFA enhancement	Session hijacking/account takeover	95%

A WAF may provide a layer of protection against some injection attempts but does not replace secure coding and parameterised database queries. MFA helps reduce account takeover but does not necessarily stop an attacker from reusing an already-hijacked active session token. An API gateway does not replace application-level authorisation or transaction validation.

The effectiveness percentages are therefore applied to their assigned ALE values for the calculation exercise; they should not be interpreted as proof that the controls independently eliminate those vulnerabilities.

5.4 Financial Evaluation Assumptions

The control evaluation uses a three-year period.

- Initial investment is paid once at the beginning of implementation.
- Annual maintenance is incurred in each of the three years.
- Annual risk reduction remains constant throughout the evaluation period.
- Gross modelled benefit is calculated as annual risk reduction multiplied by three.
- Total lifecycle cost equals initial investment plus three years of maintenance.
- Future benefits are not discounted.
- Inflation, tax, insurance recoveries and changes in exposure are excluded.

- The model assumes each proposed control achieves the stated effectiveness against its assigned scenario.

No formal budget limit was provided. Consequently, the base case evaluates all three controls together and does not claim to identify a mathematically optimal budget-constrained portfolio.

5.5 Risk Priority Method

Financial exposure is used as the principal prioritisation measure, supplemented by exploit probability, impact on critical banking operations and the sensitivity of customer data.

For this report:

- **Critical:** ALE of $10 million or more, or equivalent evidence of extreme business exposure.
- **High:** ALE from $1 million to less than $10 million, or a significant security weakness requiring timely treatment because of its potential business consequences.
- **Medium:** ALE below $1 million where the scenario does not otherwise warrant a higher rating.

6. PHASE 1: RISK EXPOSURE CALCULATION

6.1 Single Loss Expectancy (SLE)

SLE estimates the financial impact of one successful breach.

The formula is:

SLE (Single Loss Expectancy) = Cost of one successful breach

= $5,000,000

6.1.1 API Authentication Bypass

The brief states that unauthorised fund transfers could cause a maximum single incident loss of $5,000,000.

SLE = $5,000,000

Where:

SLE (Single Loss Expectancy) = Cost of one successful breach

Result: The estimated maximum loss for one API authentication bypass incident is $5,000,000.

6.1.2 Database Injection

The brief states that 500,000 customer profiles are at risk and provides an estimated cost of $250 per record for regulatory and notification costs.

Formula:

SLE ={ Records at Risk} x {Cost per Record}

500,000 x $250

= $125,000,000

Result: The estimated single-event loss is $125,000,000, assuming all 500,000 records are affected and the $250 cost applies to each affected record.

This is a scenario estimate. The number of records actually compromised and the full cost per affected record must be validated.

6.1.3 Session Hijacking

The brief states that up to 5,000 simultaneous sessions or accounts could be affected, with an average loss of $1,500 per account.

Formula:

SLE = {Accounts at Risk} x {Average Loss per Account}

SLE = 5,000 x $1,500

= $7,500,000

Result: The estimated single-event loss from session hijacking is $7,500,000.

6.2 Annual Rate of Occurrence (ARO)

The study guide defines ARO as the number of incidents expected per year.

Because the supplied values are probabilities without an identified time period, they are treated as annual ARO proxies for this exercise.

ARO Inputs

Vulnerability	Supplied Probability	Decimal Used in Model	Interpretation
API authentication bypass	15%	0.15	Assumed annual occurrence-rate proxy
Database injection	25%	0.25	Assumed annual occurrence-rate proxy
Session hijacking	40%	0.40	Assumed annual occurrence-rate proxy

These are modelling inputs and are not evidence that the organisation experiences 0.15, 0.25 or 0.40 incidents per year in actual operations.

6.3 Annualised Loss Expectancy (ALE)

ALE = SLE x ARO

6.3.1 API Authentication Bypass ALE

Given:

- SLE = $5,000,000
- ARO proxy = 0.15

Calculation:

ALE for API = $5,000,000 x 0.15

= $750,000

Interpretation: The model estimates $750,000 in annual loss exposure for the API authentication bypass scenario.

6.3.2 Database Injection ALE

Given:

- SLE = $125,000,000
- ARO proxy = 0.25

Calculation:

= $125,000,000 x 0.25

= $31,250,000

Interpretation: Database injection contributes the largest modelled annual loss exposure, at $31,250,000.

6.3.3 Session Hijacking ALE

Given:

- SLE = $7,500,000
- ARO proxy = 0.40

Calculation:

= $7,500,000 x 0.40
= $3,000,000

Interpretation: Session hijacking represents $3,000,000 in modelled annual loss exposure.

6.3.4 Combined ALE

The total modelled annual loss exposure is the sum of the three scenario ALE values.

Total ALE =
ALE for API + ALE for DB + ALE for Session hijacking

= $750,000 + $31,250,000 + $3,000,000

Total ALE = $35,000,000

Completed SLE and ALE Calculations

Vulnerability	SLE	ARO Proxy	Calculation	ALE
API authentication bypass	$5,000,000	0.15	$5,000,000 × 0.15	$750,000
Database injection	$125,000,000	0.25	$125,000,000 × 0.25	$31,250,000
Session hijacking	$7,500,000	0.40	$7,500,000 × 0.40	$3,000,000

Total	—	—	**Sum of scenario ALEs**	**$35,000,000**

6.4 Risk Prioritisation

Risk prioritisation considers financial exposure, likelihood, operational impact and the sensitivity of the affected assets.

Table 8: Risk Prioritisation Matrix

Rank	Vulnerability	ARO Proxy	SLE	ALE	Priority	Business Justification
1	Database injection	0.25	$125,000,000	$31,250,000	Critical	Largest modelled annual exposure and potential compromise of customer and financial data
2	Session hijacking	0.40	$7,500,000	$3,000,000	High	Highest supplied exploit probability and potential account takeover
3	API authentication bypass	0.15	$5,000,000	$750,000	High	Potential unauthorised transfers affecting transaction integrity and customer funds

Although the API scenario has a lower ALE than the other two scenarios, its high single-event loss and direct effect on banking transactions justify prompt treatment.

6.5 Risk Heat Map

The following heat map uses three likelihood bands and three impact bands. The impact and likelihood thresholds are assessment assumptions chosen for this exercise.

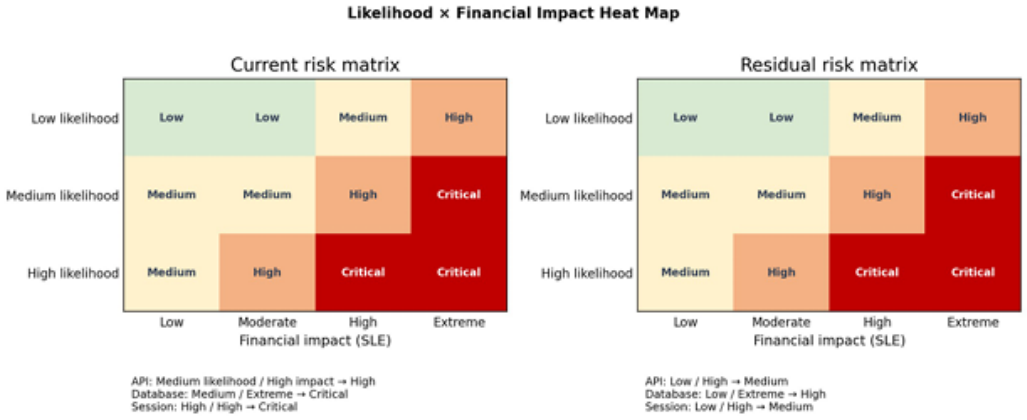
Likelihood bands

Likelihood Category	Assumed Annual Probability
Low	Below 10%
Medium	10% to below 30%
High	30% or above

Impact bands

Impact Category	Single-Event Loss
Low	Below $5,000,000
Medium	$5,000,000 to below $20,000,000
High	$20,000,000 or above

Risk Heat Map



The heat map rates database injection and session hijacking as High based on the defined likelihood-impact matrix. The financial priority rating for database injection is Critical because its modelled ALE is exceptionally high under the scenario assumptions. The two rating views serve different purposes: the heat map illustrates likelihood and event impact, while the priority table also considers the magnitude of modelled annual financial exposure.

6.6 Risk Distribution

The modelled ALE distribution is calculated by dividing each scenario ALE by the total ALE.

Formula:

Risk Share = Scenario ALE / Total ALE x 100

API Authentication Bypass

$750,000/$35,000,000 x 100

=2.14%

Database Injection

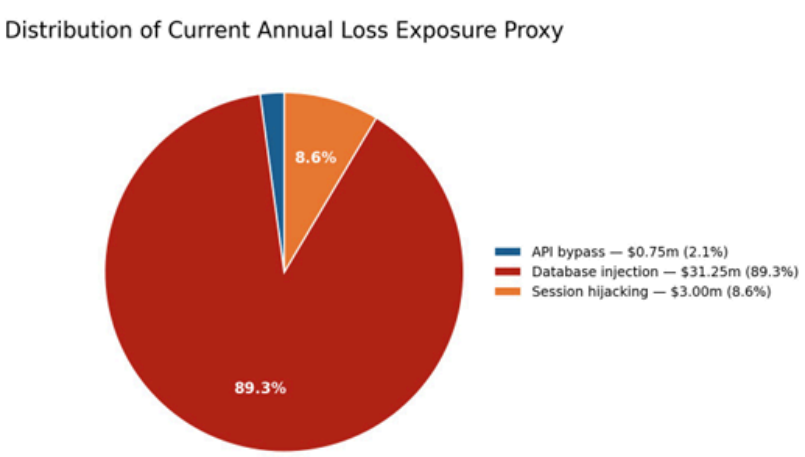
$31,250,000/$35,000,000 x100
=89.29%

Session Hijacking

$3,000,000/$35,000,000 x 100
=8.57%

Table 10: ALE Distribution

Vulnerability	ALE	Share of Total ALE
API authentication bypass	$750,000	2.14%
Database injection	$31,250,000	89.29%
Session hijacking	$3,000,000	8.57%
Total	**$35,000,000**	**100.00%**



7. PHASE 2: SECURITY CONTROL EVALUATION

7.1 Purpose of Control Evaluation

The control evaluation determines the potential financial benefit of the proposed security investments and assesses whether that benefit justifies their costs.

The study guide provides the following risk-reduction formula:
New Risk={Current Risk} x (1-{Control Effectiveness}

For this exercise, current risk is represented by the ALE of the assigned vulnerability.

Risk reduction is calculated as:

Risk Reduction=Current ALE-Residual ALE

The effectiveness value must be converted into a decimal before use. For example, 90% effectiveness is 0.90.

7.2 Control 1: Advanced API Security Gateway

Purpose

The Advanced API Security Gateway is intended to strengthen API protection and reduce the likelihood or success of API authentication-related attacks. Depending on implementation, useful capabilities may include authentication enforcement, request validation, rate limiting, transaction monitoring and integration with central security logging.

Supplied Cost Data

- Initial investment: $350,000
- Annual maintenance: $50,000
- Stated effectiveness: 90%
- Assigned scenario: API authentication bypass
- Current ALE: $750,000

Residual Risk Calculation

Residual ALE of API = $750,000 x (1-0.90)

= $750,000 x 0.10

= $75,000

Risk Reduction Calculation

Risk Reduction =
$750,000 - 75,000$
Risk Reduction =$675,000{ per year}}

The model assumes that the gateway reduces the assigned API scenario by 90%. SecureBank must confirm this effectiveness through testing and ensure that the gateway does not become a single point of failure.

The gateway should be complemented by server-side authorisation checks, validation of transaction ownership and amount, strong authentication, and alerting on suspicious transaction patterns.

7.3 Control 2: Web Application Firewall (WAF)

Purpose

The WAF is intended to inspect and filter malicious web requests and provide a defensive layer against selected web application attacks.

Supplied Cost Data

- Initial investment: $150,000
- Annual maintenance: $25,000
- Stated effectiveness: 75%
- Assigned scenario: Database injection
- Current ALE: $31,250,000

The mapping of WAF effectiveness to the database-injection scenario is a modelling assumption required for the control comparison. A WAF's actual protection against the identified injection vulnerability depends on its rules, configuration, application architecture and ability to detect the relevant payloads.

Residual Risk Calculation

Residual ALE for DB = $31,250,000 x (1-0.75)

=$31,250,000 x 0.25
=$7,812,500}

Risk Reduction Calculation

Risk Reduction_DB = $31,250,000 - 7,812,500$

Risk Reduction_DB=$23,437,500 (per year)

Despite the modelled reduction, the remaining ALE is $7,812,500. The WAF must not be treated as a replacement for correcting unsafe database queries. OWASP recommends parameterised queries or prepared statements, safe handling of dynamic query structure and least-privilege database access as important SQL injection defences (OWASP Foundation, n.d.-a).

SecureBank should therefore prioritise application-level remediation and use the WAF as a complementary layer.

7.4 Control 3: Multi-Factor Authentication (MFA) Enhancement

Purpose

MFA requires an additional authentication factor and is intended to reduce the likelihood of account takeover. It can strengthen protection against credential theft and certain authentication attacks.

Supplied Cost Data

- Initial investment: $200,000
- Annual maintenance: $30,000
- Stated effectiveness: 95%
- Assigned scenario: Session hijacking/account takeover
- Current ALE: $3,000,000

The scenario mapping follows the laboratory brief's stated reduction in account takeover. It is not a claim that MFA alone prevents theft or reuse of a valid active session token.

Residual Risk Calculation

Residual ALE of Session =
$3,000,000 x (1-0.95)
=$3,000,000 x 0.05
=$150,000

Risk Reduction Calculation

Risk Reduction - Session = $3,000,000 - 150,000$

Risk Reduction - Session=$2,850,000(per year)

MFA should be supported by secure session-token generation and storage, session rotation after authentication, appropriate idle and absolute timeouts, revocation of suspicious sessions, and reauthentication for sensitive actions. OWASP's Session Management guidance highlights that disclosure or theft of a valid session identifier can allow an attacker to impersonate a user (OWASP Foundation, n.d.-b).

7.5 Combined Residual Risk

The portfolio calculation adds the residual ALE of each assigned scenario.

Total Residual ALE = $75,000 + 7,812,500 + $150,000$

=$8,037,500

Combined Risk Reduction

Total Risk Reduction =
$35,000,000 - 8,037,500$

Total Risk Reduction =$26,962,500 (per year)

Percentage Risk Reduction

Percentage Reduction = $26,962,500/$35,000,000 x 100

= 77.0357%

Percentage Reduction approximately 77.04%

Current Versus Residual Risk

Vulnerability	Current ALE	Control Applied	Modelled Reduction	Residual ALE
API authentication bypass	$750,000	API Security Gateway	$675,000	$75,000
Database injection	$31,250,000	WAF	$23,437,500	$7,812,500
Session hijacking	$3,000,000	MFA enhancement	$2,850,000	$150,000
Total	**$35,000,000**	**Three assigned controls**	**$26,962,500**	**$8,037,500**

The total assumes that the individual risk scenarios can be added without overlapping losses and that each control's effectiveness applies only to its assigned risk. If future evidence shows that a single incident could cause losses across multiple scenarios, the model must be adjusted to prevent double-counting of underlying losses as well as control benefits.

7.6 Control Investment Analysis

Initial Investment

350, 000 +150,000+$200,000 = $700,000

Annual Maintenance

50, 000 +25,000+$30,000
=$105,000

Three-Year Maintenance

$105,000 x 3= $315,000

Three-Year Lifecycle Cost

Lifecycle Cost =Initial Investment +
Annual Maintenance x 3

For the combined portfolio:

700, 000 +315,000
= $1,015,000

Table 12: Investment Breakdown

Control	Initial Investment	Annual Maintenance	Three-Year Maintenance	Three-Year Lifecycle Cost
Advanced API Security Gateway	$350,000	$50,000	$150,000	$500,000
WAF	$150,000	$25,000	$75,000	$225,000
MFA enhancement	$200,000	$30,000	$90,000	$290,000
Total	**$700,000**	**$105,000/year**	**$315,000**	**$1,015,000**

7.7 Return on Investment (ROI)

Formula:

ROI = (Benefit - Cost) ÷ Cost × 100

For consistent comparison, the report uses a three-year evaluation period.

Three-year benefit is defined as modelled annual gross risk reduction multiplied by three.

Three-year cost is defined as initial investment plus three years of maintenance.

Three-year net modelled benefit equals three-year gross benefit minus three-year lifecycle cost.

These are expected-loss estimates rather than guaranteed savings in cash.

7.7.1 Advanced API Security Gateway ROI

Annual risk reduction:

$675,000

Three-year gross benefit:
675, 000 × 3 =2,025,000

Three-year cost:
$350,000 + (50,000 \times 3) = \$500,000$

ROI:

$ROI = (2,025,000 - 500,000)/\$500,000 \times 100$

$=\$1,525,000/\$500,000 \times 100$

ROI =305.0%

Three-year net modelled benefit:

$2,025,000 - 500,000 = \$1,525,000$

7.7.2 Web Application Firewall ROI

Annual risk reduction:

$23,437,500

Three-year gross benefit:

$23,437,500 \times 3 = 70,312,500$

Three-year cost:

$150,000 + (25,000 \times 3) = \$225,000$

ROI:

$ROI = (70,312,500 - 225,000) / \$225,000 \times 100$

$=\$70,087,500/\$225,000 \times 100$

ROI =31,150.0%

Three-year net modelled benefit:

$$70,312,500 - 225,000 = \$70,087,500$$

This unusually high result is heavily influenced by the $125 million database-injection SLE assumption. It should be validated rather than treated as an assured financial return.

7.7.3 MFA Enhancement ROI

Annual risk reduction:

$$\$2,850,000$$

Three-year gross benefit:

$$2,850,000 \times 3 = 8,550,000$$

Three-year cost:

$$200,000 + (30,000 \times 3) = \$290,000$$

ROI:

$$ROI = (8,550,000 - 290,000) / \$290,000 \times 100$$

$$= \$8,260,000 / \$290,000 \times 100$$

ROI is approximately = 2,848.3%

Three-year net modelled benefit:

$$8,550,000 - 290,000 = \$8,260,000$$

Three-Year ROI Comparison

Control	Annual Risk	Three-Year	Initial Investment	Three-Year	Three-Year	Three-Year Net Benefit	ROI

	Reduction	Gross Benefit		Maintenance	Total Cost		
Advanced API Security Gateway	$675,000	$2,025,000	$350,000	$150,000	$500,000	$1,525,000	305.0%
WAF	$23,437,500	$70,312,500	$150,000	$75,000	$225,000	$70,087,500	31,150.0%
MFA enhancement	$2,850,000	$8,550,000	$200,000	$90,000	$290,000	$8,260,000	2,848.3%
Combined portfolio	**$26,962,500**	**$80,887,500**	**$700,000**	**$315,000**	**$1,015,000**	**$79,872,500**	**7,869.2%**

Combined Portfolio ROI

ROI =
(80, 887, 500 −1,015,000)/$1,015,000 x 100

=$79,872,500/$1,015,000 x 100

Portfolio ROI is approximately 7,869.2%

The portfolio ROI is a combined weighted calculation using total gross benefit and total lifecycle cost. It is not the sum or simple average of the three individual ROI percentages.

7.8 Payback Period

The estimated payback period is calculated using the following formula:

Payback (months) =
Initial Investment /
(Annual Risk Reduction)-(Annual Maintenance)
x 12

This formula assumes the risk-reduction benefit is realised evenly throughout the year and the annual maintenance cost is incurred in the same period.

7.8.1 Advanced API Security Gateway

Payback = $350,000/($675,000-$50,000) x 12

=$350,000 / $625,000 x 12
Payback is approximately 6.72 months

7.8.2 WAF

Payback =
$150,000 /($23,437,500-$25,000) x 12

=$150,000/$23,412,500 x 12
Payback is approximately 0.08(months)

This is less than one day under the simplified model. It should not be interpreted as a guarantee that the WAF will recover its purchase cost in less than one day in actual operations.

7.8.3 MFA Enhancement

Payback= $200,000/($2,850,000-$30,000) x 12

= $200,000/$2,820,000 x 12

Payback is approximately 0.85(months)

Table 14: Control Payback Comparison

Control	Initial Investment	Annual Risk Reduction	Annual Maintenance	Annual Net Modelled Benefit	Estimated Payback
Advanced API Security Gateway	$350,000	$675,000	$50,000	$625,000	6.72 months
WAF	$150,000	$23,437,500	$25,000	$23,412,500	0.08 months
MFA enhancement	$200,000	$2,850,000	$30,000	$2,820,000	0.85 months

7.9 Control Selection Analysis

The base-case model supports evaluating all three controls, subject to validation of each control's effectiveness and applicability.

Advanced API Security Gateway

The gateway addresses API-specific exposure and has a modelled three-year ROI of 305.0%. It should be selected if testing confirms that its controls effectively address the identified authentication bypass and associated transaction risks.

Web Application Firewall

The WAF has the highest modelled financial benefit because it is assigned to the largest ALE scenario. However, it must be implemented as a supplementary defence and must not replace direct remediation of the database injection vulnerability.

MFA Enhancement

MFA has a modelled three-year ROI of 2,848.3% and addresses account takeover exposure. Its value depends on correct implementation and integration with secure session management. It should be complemented by revocation of compromised sessions and strong controls around sensitive transactions.

Table 15: Cost Versus Effectiveness

Control	Initial Cost	Stated Effectiveness	Modelled Annual Risk Reduction
Advanced API Security Gateway	$350,000	90%	$675,000
WAF	$150,000	75%	$23,437,500
MFA enhancement	$200,000	95%	$2,850,000

Combined Control Selection

Because no budget cap was provided and the three controls address different primary risks, the base case evaluates all three together.

The proposed combined investment is $700,000 upfront and $105,000 annually for maintenance. Before approval, SecureBank should validate the cost estimates, implementation dependencies, likely operational impacts and effectiveness of the proposed controls.

If management later provides a fixed budget limit, the control selection should be recalculated using that limit and an explicitly defined objective, such as minimising residual ALE within budget.

8. PHASE 3: EXECUTIVE DASHBOARD AND REPORTING

8.1 Executive Dashboard

Table 16: Executive Dashboard Metrics

Metric	Current Model	Model After Proposed Controls
Total annual loss exposure	$35,000,000	$8,037,500
Annual modelled risk reduction	—	$26,962,500
Percentage reduction	—	77.04%
Initial control investment	—	$700,000
Annual maintenance	—	$105,000
Three-year lifecycle cost	—	$1,015,000
Three-year gross modelled benefit	—	$80,887,500
Three-year net modelled benefit	—	$79,872,500
Three-year portfolio ROI	—	7,869.2%
Highest financial priority	Database injection	Database injection remains the largest residual ALE scenario

8.2 Risk Exposure Before and After Controls

Current Versus Residual ALE

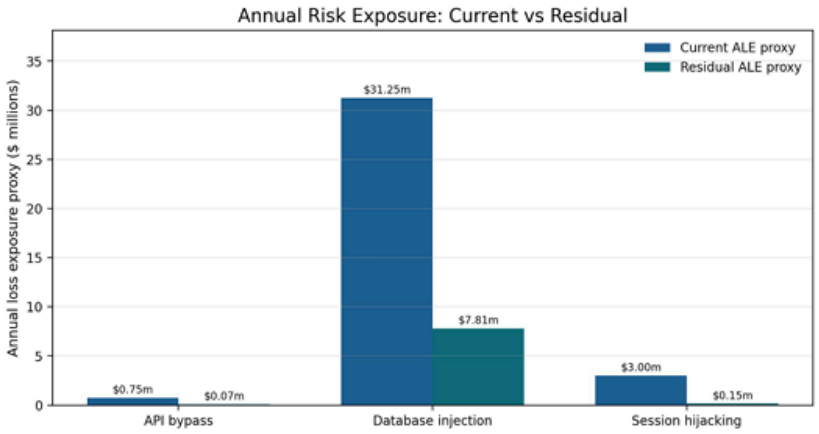
Vulnerability	Current ALE	Residual ALE
API authentication bypass	$750,000	$75,000

Database injection	$31,250,000	$7,812,500
Session hijacking	$3,000,000	$150,000
Total	**$35,000,000**	**$8,037,500**

8.3 ALE Comparison

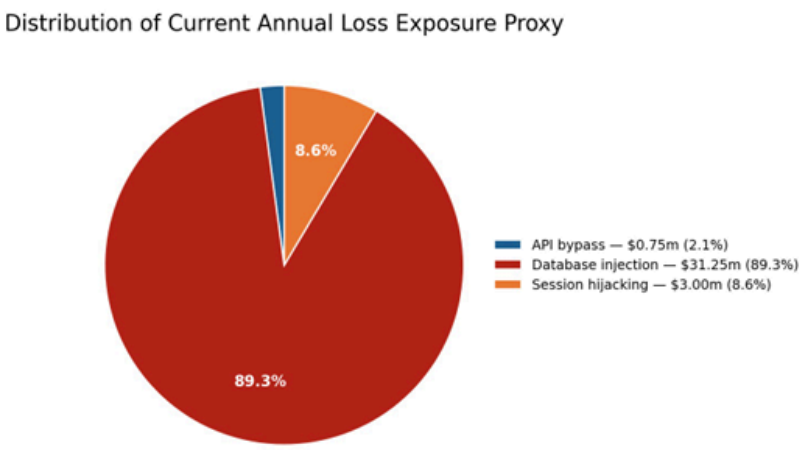
Annualised Loss Expectancy by Vulnerability.

The chart uses vulnerability names on the horizontal axis and ALE in USD on the vertical axis.



8.4 ALE Distribution

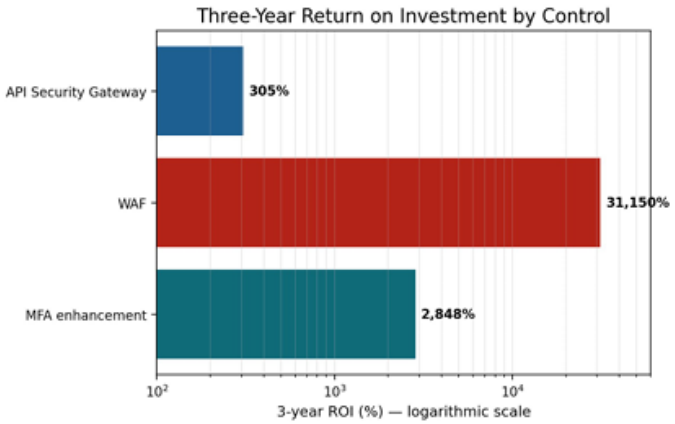
Vulnerability	ALE Share
API authentication bypass	2.14%
Database injection	89.29%
Session hijacking	8.57%



8.5 ROI Comparison Chart

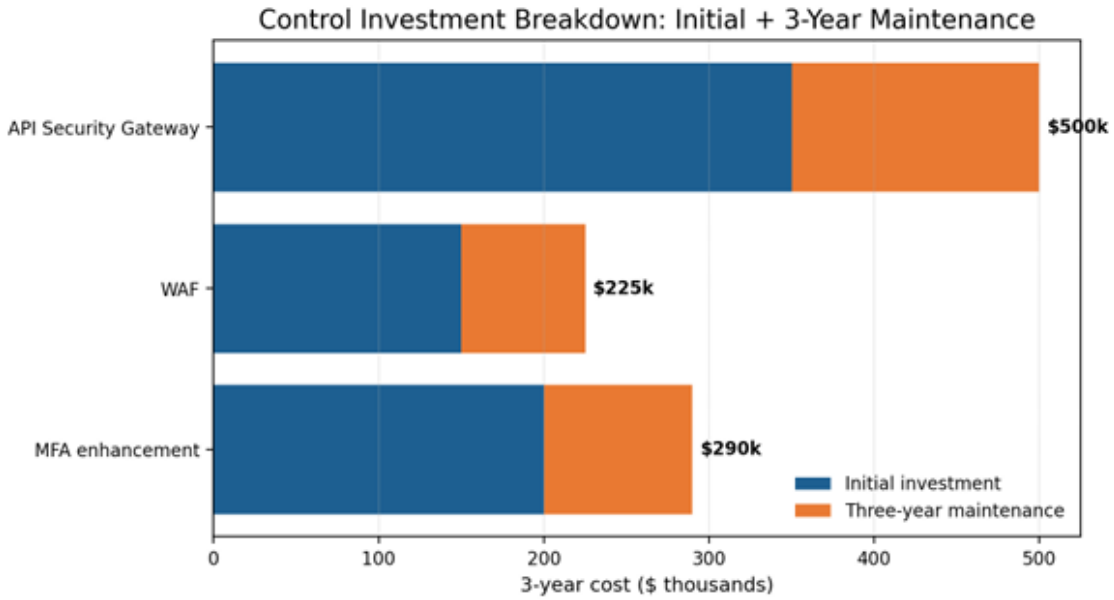
Chart Data — Three-Year ROI

Control	ROI
Advanced API Security Gateway	305.0%
WAF	31,150.0%
MFA enhancement	2,848.3%



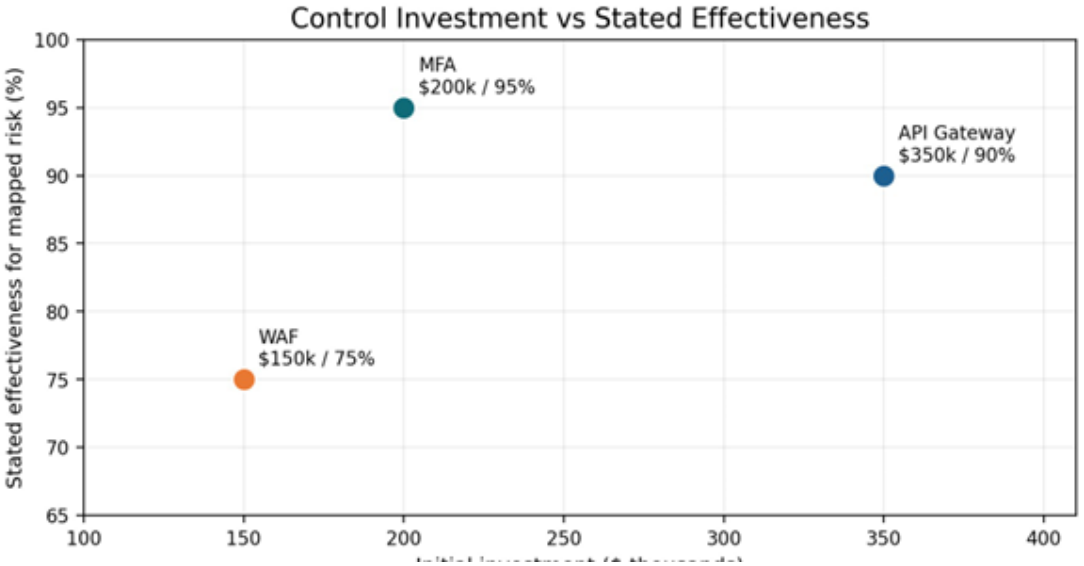
8.6 Investment Breakdown

- Horizontal axis: Security control.
- Vertical axis: Cost in USD.
- First series: Initial investment.
- Second series: Three-year maintenance.



8.7 Control Cost Versus Effectiveness Scatter Plot

- Horizontal axis: Initial cost in USD.
- Vertical axis: control effectiveness (%).



The plot helps management compare upfront expenditure and stated effectiveness. It does not prove that the most effective control provides the greatest financial benefit, because each control addresses a different risk and the risks have different financial exposure.

8.8 Risk Reduction Over Time

Table 19: Cumulative Gross Modelled Risk Reduction

Evaluation Year	API Gateway Benefit	WAF Benefit	MFA Benefit	Cumulative Portfolio Benefit
Year 1	$675,000	$23,437,500	$2,850,000	$26,962,500
Year 2	$1,350,000	$46,875,000	$5,700,000	$53,925,000
Year 3	$2,025,000	$70,312,500	$8,550,000	$80,887,500

9. RISK TREATMENT PLAN AND IMPLEMENTATION TIMELINE

9.1 Treatment Strategy

The treatment strategy prioritises direct remediation of vulnerabilities and the implementation of complementary security controls.

The first priority is database injection because it represents the largest modelled ALE. API authentication bypass and session hijacking must also be addressed because both threaten transaction integrity and customer account security.

Control deployment should not be considered complete merely because a product has been purchased or installed. SecureBank should verify that each control addresses the actual attack path, operates correctly and reduces the intended risk.

9.2 Immediate Actions: Days 0–30

Table 20: Immediate Treatment Plan

Action	Risk Addressed	Suggested Owner	Target	Evidence of Completion
Validate record count and $250 cost-per-record assumption	Database injection	GRC and Data Protection	Day 10	Documented assumptions and revised impact estimate
Review and remediate unsafe database queries	Database injection	Application Development	Day 30	Code review and testing evidence

Apply least-privilege database permissions	Database injection	Database Administrator	Day 30	Permission review and approved access matrix
Review API authentication and authorisation paths	API bypass	API Engineering and Security	Day 15	Test results and documented remediation
Review session lifecycle and token handling	Session hijacking	Application Security	Day 30	Session-management review and test cases
Establish incident monitoring and escalation criteria	All scenarios	Security Operations	Day 30	Alert rules and documented escalation procedure

Expected outcome: Immediate exposure is reduced through direct remediation, temporary safeguards and improved visibility while the longer-term control deployments are prepared.

9.3 Short-Term Controls: Days 31–90

Short-Term Treatment Plan

Action	Risk Addressed	Suggested Owner	Target	Evidence of Completion
Deploy and configure the WAF	Web attacks and database-injection attempts	Infrastructure Security	Day 60	Configuration review and testing results
Implement the API Security Gateway	API authentication bypass	API Engineering	Day 75	Authentication, authorisation and rate-limit testing
Deploy MFA enhancements	Account takeover	IAM Team	Day 75	Authentication test results and adoption metrics
Integrate security logs with monitoring	All scenarios	Security Operations	Day 90	Verified alerting and incident escalation
Conduct retesting of all three vulnerabilities	All scenarios	Independent Security Tester	Day 90	Retest report showing resolved and outstanding findings
Recalculate residual risk	All scenarios	GRC Analyst	Day 90	Updated and approved risk register

Expected outcome: Proposed controls are implemented and tested, vulnerabilities are retested, and the risk register is updated with evidence-based residual risk.

9.4 Long-Term Strategy: Days 91–365

Long-Term Treatment Plan

Action	Purpose	Suggested Owner	Target	Success Measure
Establish recurring vulnerability assessments	Identify new or recurring weaknesses	Vulnerability Management	Quarterly	Findings tracked through closure
Perform periodic penetration testing	Validate security controls	Independent Security Tester	At least annually	Retest and remediation evidence
Review control effectiveness	Confirm stated effectiveness is achieved	GRC and Security Engineering	Quarterly	Documented effectiveness review
Conduct incident-response exercises	Improve readiness and response	Security Operations	Within 6 months	Exercise report and action tracking
Review access and privileged accounts	Reduce unauthorised access	IAM and System Owners	Quarterly	Access reviews completed
Refresh quantitative risk estimates	Keep risk figures aligned to real data	GRC and Finance	Quarterly or after significant events	Updated ALE and impact assumptions
Report risk trends to management	Support governance and investment decisions	GRC Analyst	Quarterly	Dashboard submitted to CISO and CFO

Expected outcome: SecureBank establishes ongoing monitoring and assurance so that risk treatment remains effective as the platform, threat environment and business operations change.

9.5 Gantt-Style Treatment Timeline

Table 23: Phased Implementation Timeline

Activity	Days 0–30	Days 31–60	Days 61–90	Months 4–6	Months 7–12
Validate financial assumptions	■			Review	Review
Remediate database injection	■	■	Retest	Monitor	Retest
Review API authentication	■	■	Retest	Monitor	Retest
Review session management	■	■	Retest	Monitor	Retest
Deploy WAF	Plan	■	Tune and test	Monitor	Review
Deploy API Security Gateway	Plan	■	Test and tune	Monitor	Review
Deploy MFA enhancement	Plan	■	Test and tune	Monitor	Review
Recalculate residual risk	Baseline		■	■	■
Report to CISO and CFO	Initial	Progress	Review	Quarterly	Annual review

Legend: ■ = planned active period; “Plan,” “Retest,” “Monitor” and “Review” indicate the relevant project activity. The schedule is illustrative and must be confirmed by management before implementation.

10. MONITORING, MEASUREMENT AND ASSURANCE

10.1 Purpose

Risk treatment must be monitored to confirm that the controls achieve their intended outcomes and that the residual exposure remains acceptable.

The modelled risk reductions should be treated as hypotheses until supported by technical testing and operational evidence.

10.2 Key Risk Indicators

Recommended Monitoring Metrics

Metric	Purpose	Measurement Frequency
Number of confirmed API authentication bypass findings	Measure recurrence of the identified API weakness	Monthly and after major releases
Number of unresolved database injection findings	Track remediation progress	Monthly
Number of confirmed session hijacking incidents	Monitor account and session compromise	Monthly
Percentage of critical findings resolved within SLA	Measure remediation timeliness	Monthly
WAF rule effectiveness and false-positive rate	Check defensive value and service impact	Monthly
API gateway authentication/authorisation test results	Verify protection of transaction endpoints	After changes and quarterly
MFA coverage for in-scope users	Measure deployment and adoption	Monthly
Number of compromised sessions revoked within target	Measure session response effectiveness	Monthly
Actual financial losses from relevant incidents	Improve loss and impact estimates	Quarterly
Residual ALE and treatment status	Support management oversight	Quarterly

10.3 Control Assurance

The following assurance activities should be performed:

1. Re-test the original vulnerabilities after remediation.
2. Verify that controls protect the actual affected endpoints and business processes.
3. Confirm that security logs contain sufficient information for detection and investigation.
4. Test alerting and escalation paths.
5. Document exceptions, limitations and unresolved risks.
6. Recalculate risk estimates when the underlying assumptions or control effectiveness change.
7. Obtain risk-owner acceptance for residual risks that cannot be fully eliminated.

The GRC analyst should retain supporting evidence, including approved configurations, test results, remediation tickets, risk-register updates and management decisions.

11. LIMITATIONS AND KEY ASSUMPTIONS

11.1 Probability and ARO Limitation

The input probabilities do not specify a time period. Treating them as annual occurrence-rate proxies is an explicit assumption made to complete the laboratory calculations. A real risk assessment should establish whether the probabilities represent annual likelihood, test-period likelihood or another measure.

11.2 Financial Impact Limitation

The database-injection SLE assumes that all 500,000 records are affected at $250 per record. This may overstate or understate actual loss depending on the number of records compromised, incident circumstances, actual notification requirements, recovery costs, legal costs and applicable regulatory outcomes.

The session-hijacking scenario assumes that all 5,000 accounts or sessions at risk experience the stated average loss. Actual loss may differ depending on the number of accounts successfully compromised, transaction controls, reimbursement, recovery and fraud detection.

The API scenario uses the supplied maximum loss of $5,000,000.

11.3 Control Effectiveness Limitation

The model applies each control's percentage reduction directly to the ALE of one assigned scenario. This is useful for demonstrating the formula, but actual protection depends on deployment, configuration, application architecture and the specific attack path.

In particular:

- A WAF should not be treated as a substitute for secure database query construction and least-privilege database access.
- An API gateway does not replace server-side authorisation or validation of each sensitive transaction.
- MFA does not necessarily prevent reuse of an already-hijacked authenticated session.
- Overlapping controls must be assessed carefully to avoid double-counting the same financial benefit.

11.4 ROI and Payback Limitations

ROI is based on expected loss avoidance, not guaranteed financial savings. The three-year model assumes a constant annual risk reduction and excludes discounting, inflation and changes in threat exposure.

The payback period assumes that modelled annual risk reduction is realised evenly over the year. The unusually short modelled WAF payback period reflects the large assumed database-injection exposure and must not be interpreted as a certain real-world recovery period.

11.5 Budget and Implementation Limitations

No formal budget limit, procurement timeline, staffing allocation or implementation dependency data were supplied. The three-year evaluation period and treatment timeline are stated assumptions for planning purposes.

A real deployment decision should include project costs, operational impacts, integration effort, control testing, staff training, vendor terms and ongoing support requirements.

12. CONCLUSION AND MANAGEMENT RECOMMENDATIONS

12.1 Conclusion

The SecureMobile quantitative cybersecurity risk assessment demonstrates how technical vulnerabilities can be translated into estimated financial exposure to support security investment decisions.

Using the assumptions stated in this report, the combined annual loss exposure is estimated at $35,000,000. Database injection is the highest financial priority, with a modelled ALE of $31,250,000. Session hijacking carries a modelled ALE of $3,000,000, while API authentication bypass carries a modelled ALE of $750,000.

The three proposed controls require an initial investment of $700,000 and annual maintenance of $105,000. Over three years, the combined lifecycle cost is $1,015,000. If each control achieves the assumed effectiveness against its assigned scenario, the model estimates annual risk reduction of $26,962,500 and residual annual loss exposure of $8,037,500.

The resulting portfolio ROI of approximately 7,869.2% is a scenario-based calculation of expected loss avoided, not a guaranteed return. It is especially sensitive to the database-injection loss assumption and the application of WAF effectiveness to that risk.

12.2 Recommendations to the CISO

The CISO should:

1. Prioritise direct remediation of database injection, including parameterised queries, safe input handling, least-privilege database access and retesting.
2. Review API authentication and authorisation logic, especially controls governing fund transfers and sensitive transactions.
3. Strengthen session management alongside MFA, including secure token handling, appropriate timeouts, session revocation and detection of suspicious activity.
4. Validate the stated control effectiveness through technical testing.
5. Require evidence that findings have been resolved before accepting residual-risk estimates.
6. Assign accountable owners and monitor progress through a risk register and quarterly reporting.

12.3 Recommendations to the CFO

The CFO should:

1. Review the proposed $700,000 initial investment and $105,000 annual maintenance requirement.
2. Treat the ROI and payback calculations as model outputs based on expected loss avoidance.
3. Request validation of the $250 per-record cost and the assumption that all 500,000 records may be affected in one incident.
4. Require confirmation that the WAF and other proposed controls address the relevant vulnerabilities.
5. Monitor actual implementation expenditure against the approved budget.
6. Review revised financial estimates when incident data, validated loss assumptions or control test results become available.

12.4 Final Management Decision Requested

The recommended decision is to approve progression into a structured risk-treatment programme, subject to financial validation and technical verification.

The immediate priority should be database-injection remediation and deployment of a supporting WAF. The API Security Gateway and MFA enhancement should progress in parallel according to implementation dependencies and the agreed treatment schedule.

The organisation should not rely on the modelled control reductions until they have been validated through testing. Risk owners should document any residual risk that remains after treatment and seek the appropriate management approval for acceptance.

This approach provides SecureBank Financial with a transparent basis for prioritising remediation, allocating security investment and reporting cybersecurity risk in financial and business terms.

13. REFERENCES

National Institute of Standards and Technology. (2012). *Guide for conducting risk assessments* (NIST Special Publication 800-30, Revision 1). U.S. Department of Commerce. https://doi.org/10.6028/NIST.SP.800-30r1

OWASP Foundation. (n.d.-a). *SQL injection prevention cheat sheet*. OWASP Cheat Sheet Series. https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html

OWASP Foundation. (n.d.-b). *Session management cheat sheet*. OWASP Cheat Sheet Series. https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html

OWASP Foundation. (n.d.-c). *OWASP API Security Project*. https://owasp.org/projects/api-security-project

Lab 3b: Advanced Cybersecurity Risk Quantification — SecureBank Financial SecureMobile Banking Platform Assessment. (n.d.). Laboratory scenario and assessment brief supplied for the exercise.

Study Guide: Quantitative Risk Calculations for GRC Professionals. (n.d.). Course learning material supplied for the exercise.